

Chapitre 2

Logiciels malveillants

Présenté par:

Wassim Abbessi



Contenu

Définitions

Virus

Ver

Logiciel espion

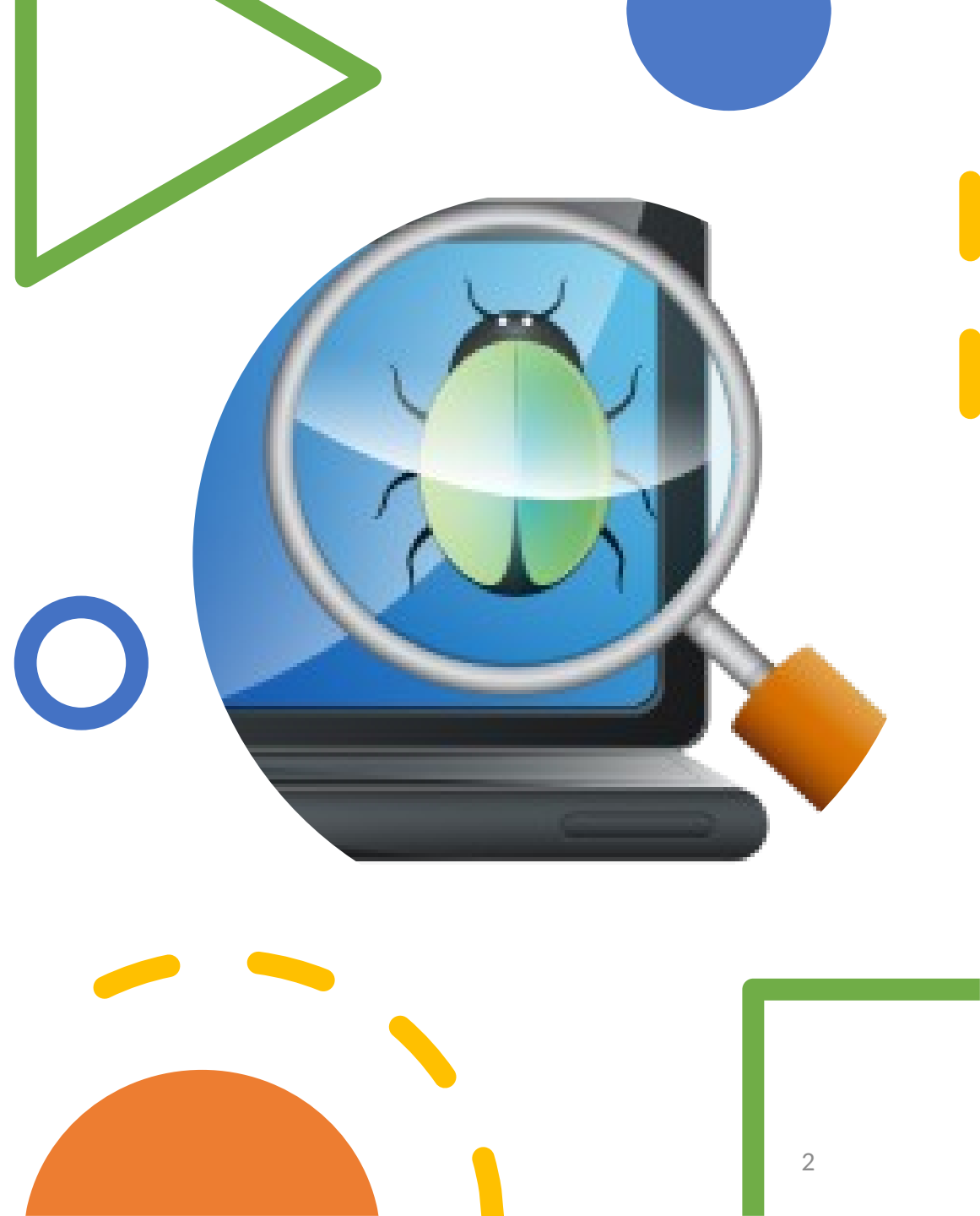
Réseau de bots

Keylogger

Porte dérobée

Malware Bluetooth et mobile

Rançongiciel



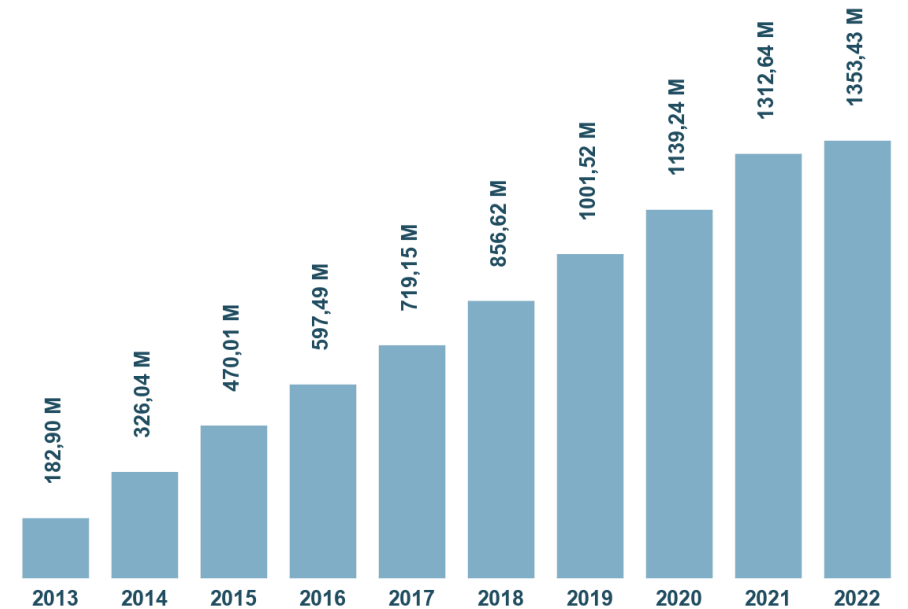
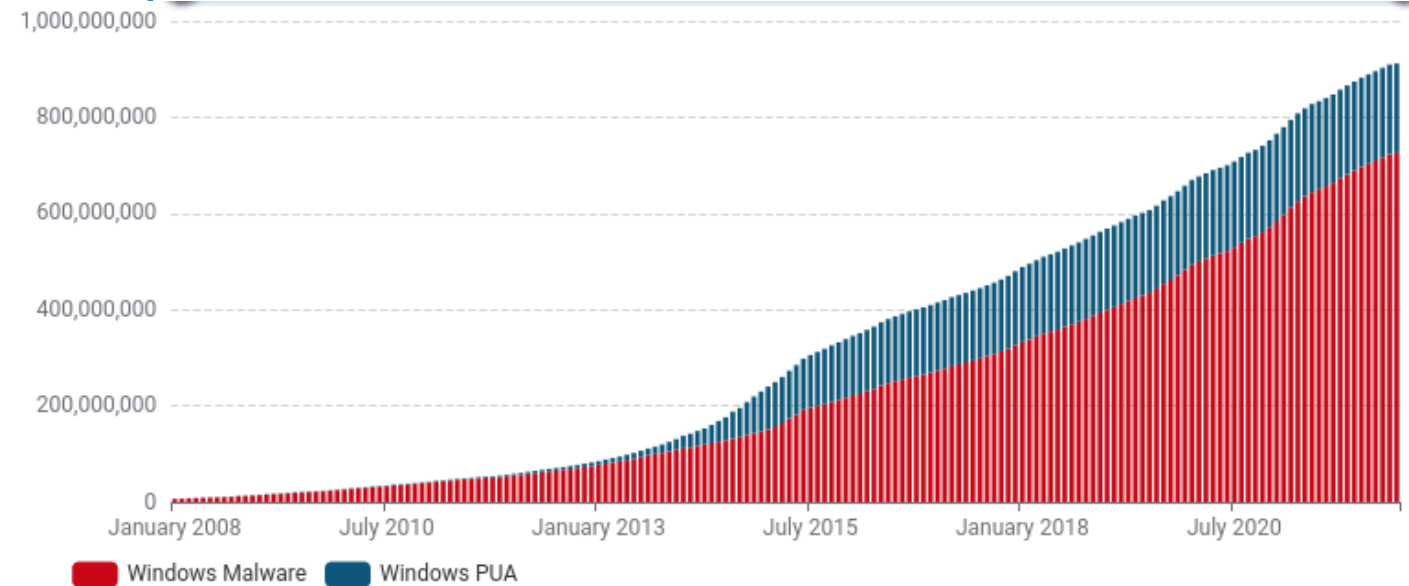
Logiciel malveillant

Logiciel malicieux qui endommage ou plante les systèmes

Peut donner un accès limité ou total à son créateur

Vise généralement une opération illégale

Evolution du nombre de logiciels malveillants



Dernière mise à jour: 11 Mai 2022

Copyright © AV-TEST GmbH www.av-test.org

Sources de malwares

- Périphériques amovibles
- Attachements
- Faux programmes
- Navigateur bogue
- Sites de téléchargement de logiciels
 - Jeux
 - Programmes
 - Economiseurs d'écrans
 - Fichiers bureautiques
- Partage de fichiers
- IRC (Internet Relay Chat)

Techniques communes des malwares sur le web

- Compromettre des sites légitimes et y ajouter des malwares
- Ajouter des malwares dans les scripts publicitaires
- Tromper l'utilisateur pour cliquer sur un mauvais lien
- Copier l'apparence d'un site institutionnel pour voler des informations
- Exploiter des failles sur les navigateurs pour installer des malwares juste en visitant un site

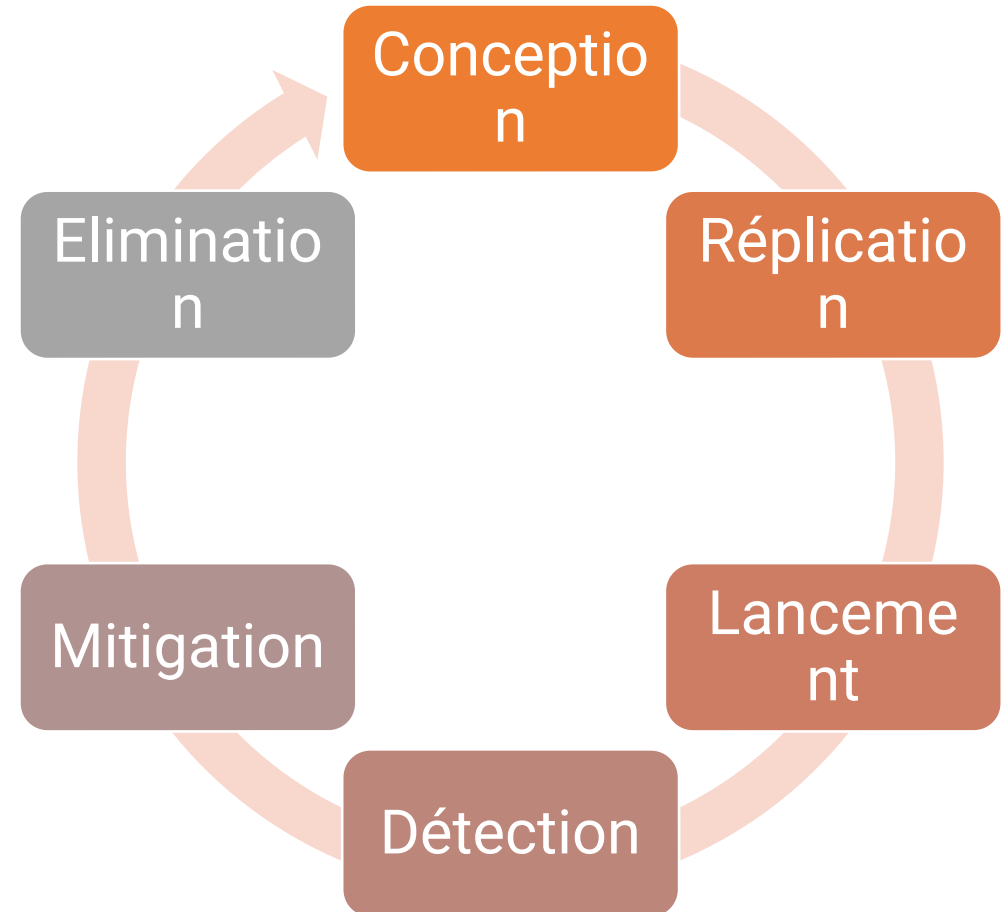
Le virus

- Programme capable d'infecter d'autres programmes pour qu'ils contiennent une copie de lui-même
- Change les configurations de l'OS
- Peut détruire le système et le mettre hors service en consommant toutes les ressources système
- Peut endommager les supports de stockage
- Peut changer de nom, de taille et de forme (polymorphe, métamorphe)
- Peut être crypté
- Peut rester résident en mémoire

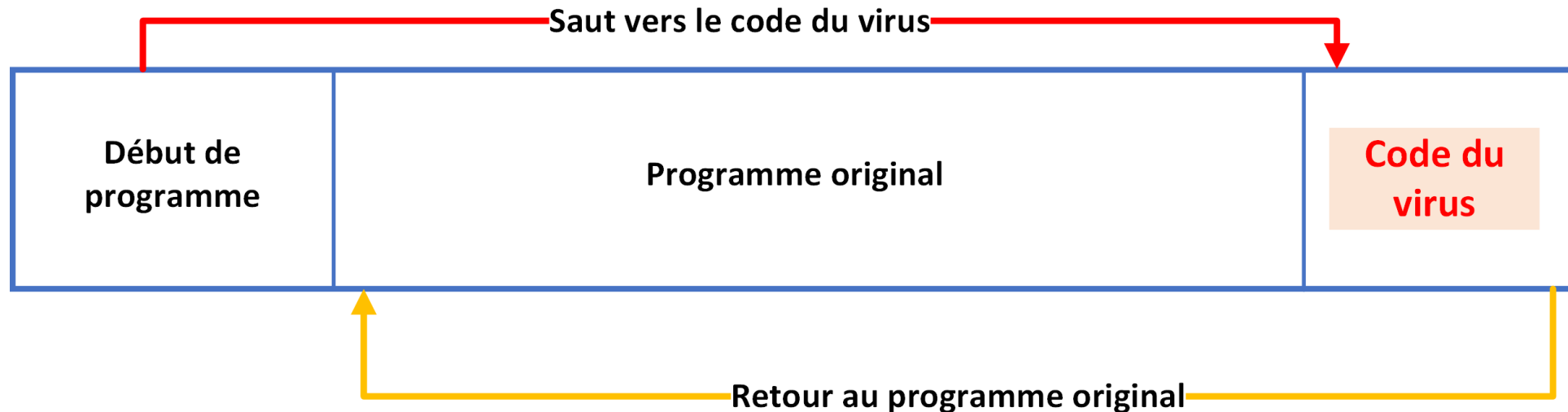
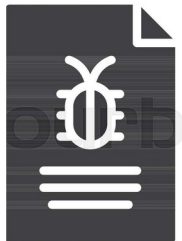


Les virus

- Sont généralement transmis via
 - les flashes,
 - Les partages de fichiers
 - Les téléchargements
 - Les emails (pièce jointe)
- Ont un cycle de vie en boucle



Virus: Mécanisme d'infection



Virus: Signes de présence

- Des processus consomment beaucoup de ressources CPU
- Changement des tailles des fichiers
- Changement de noms de fichiers, dossiers et lecteurs
- Alertes anti-virus
- Plantages et erreurs fréquentes
- Fichiers manquants
- Activité anormale sur le disque



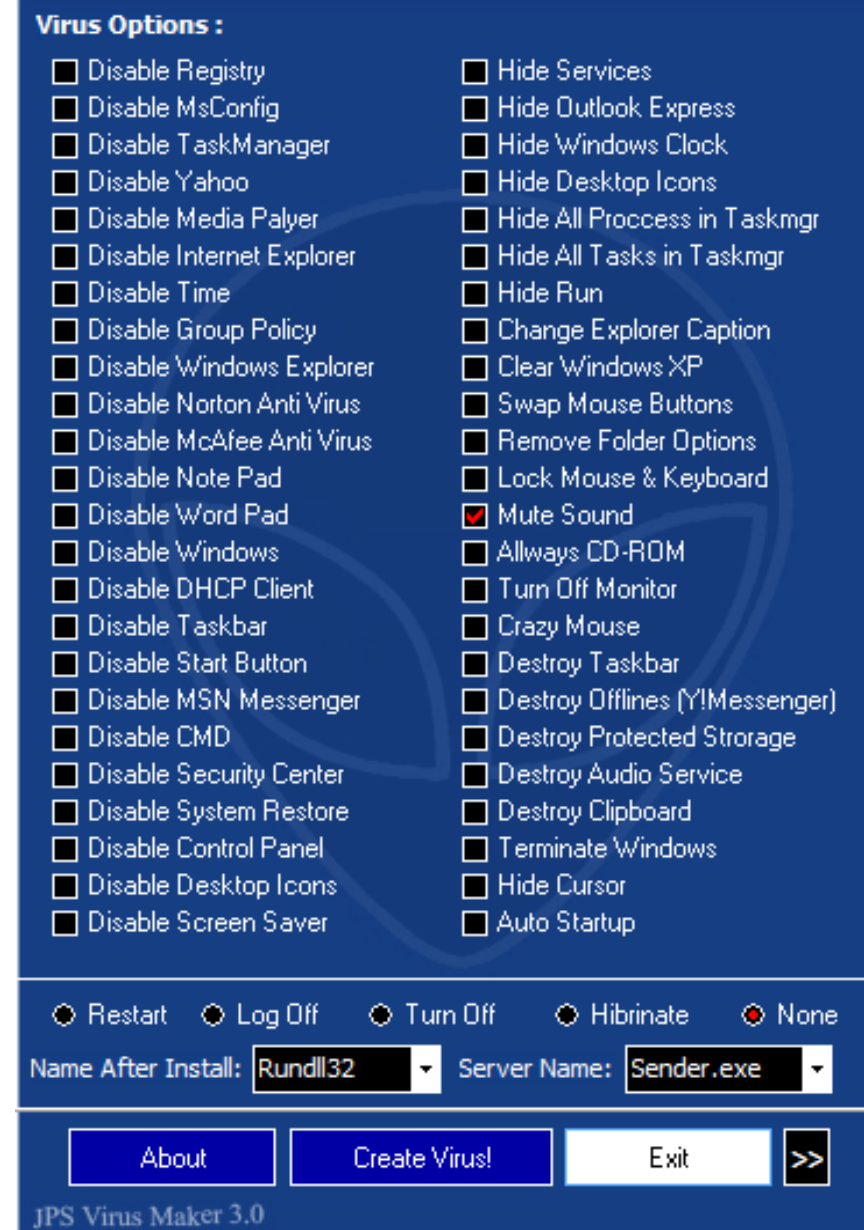
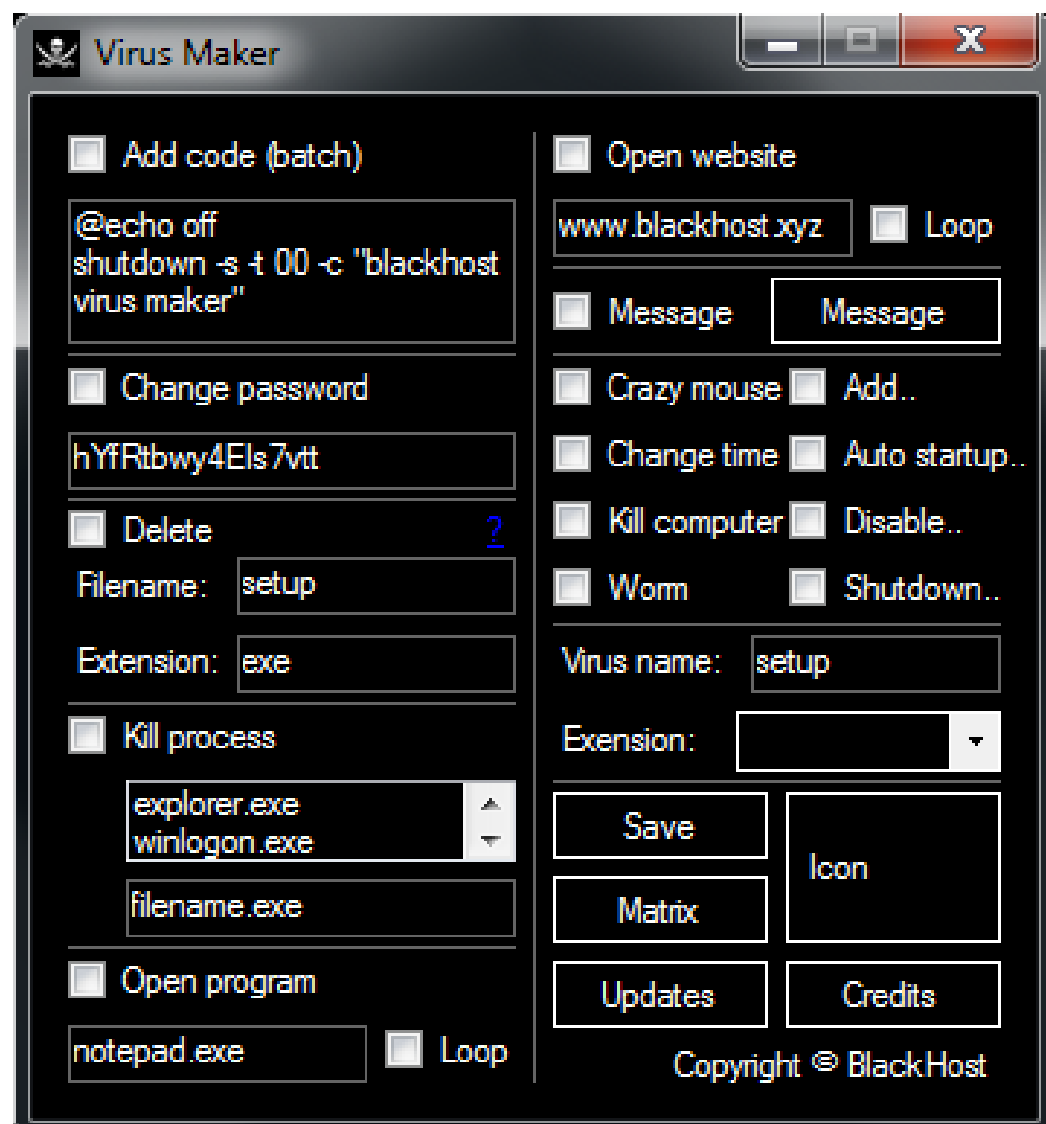
Les macro-virus



- Infectent les fichiers bureautiques (Word, Excel)
- Sont écrits en utilisant le langage VBA
- Infectent les *templates* des fichiers pour se copier automatiquement sur tous les nouveaux fichiers
- Changement automatique du contenu des fichiers

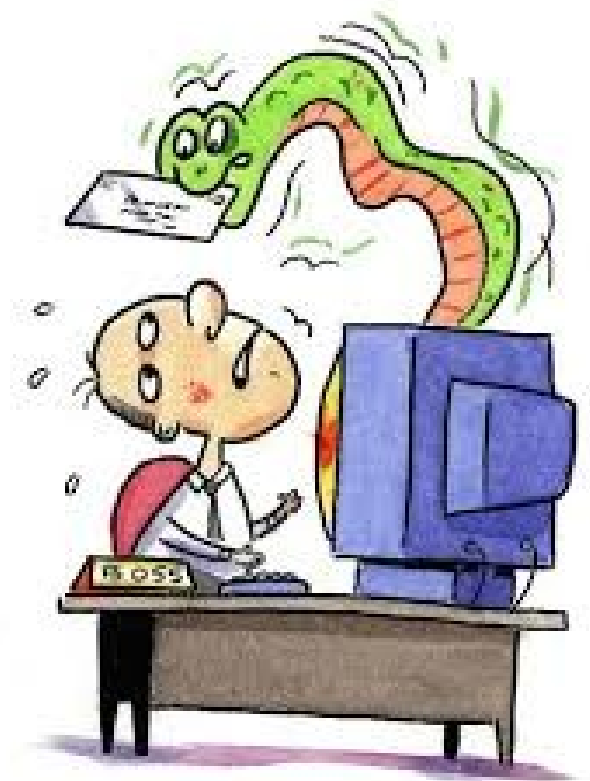


Virus makers

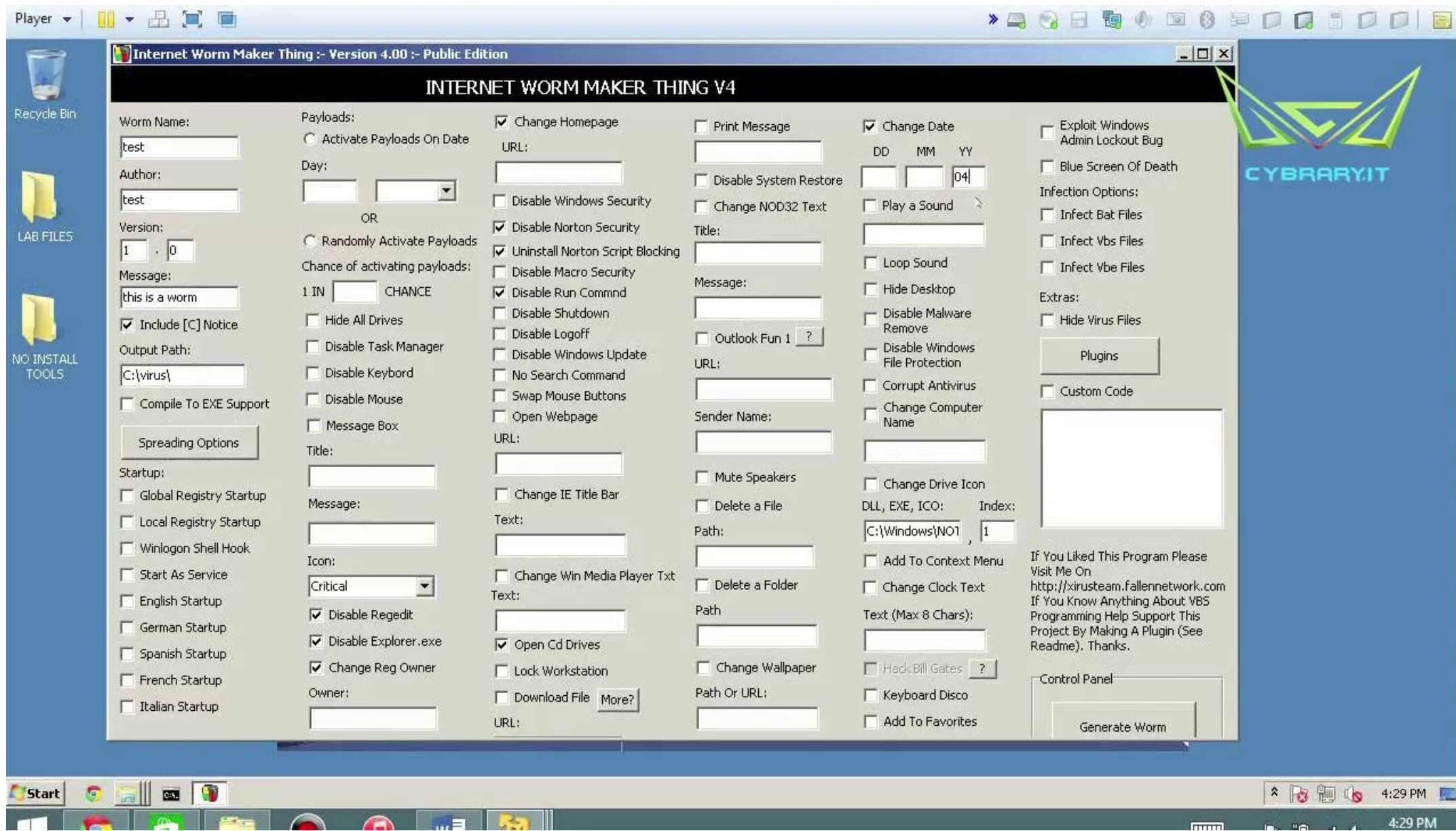


Les vers (worms)

- Programme malicieux qui se propage rapidement sur les réseaux
- Utilise le PC comme base pour se répandre sur le réseau et infecter le plus grand nombre de PCs
- Peut viser une cible fixée à une date future (bombe logique)
- Risque de congestion des réseaux à cause de la rapidité de propagation
- En 2000, le ver **loveletter** a infecté 10% des ordinateurs du monde en quelques heures (8.7 milliards de dollars de pertes)



Worm maker



Exemple e ver loveletter.vbs



Les spywares



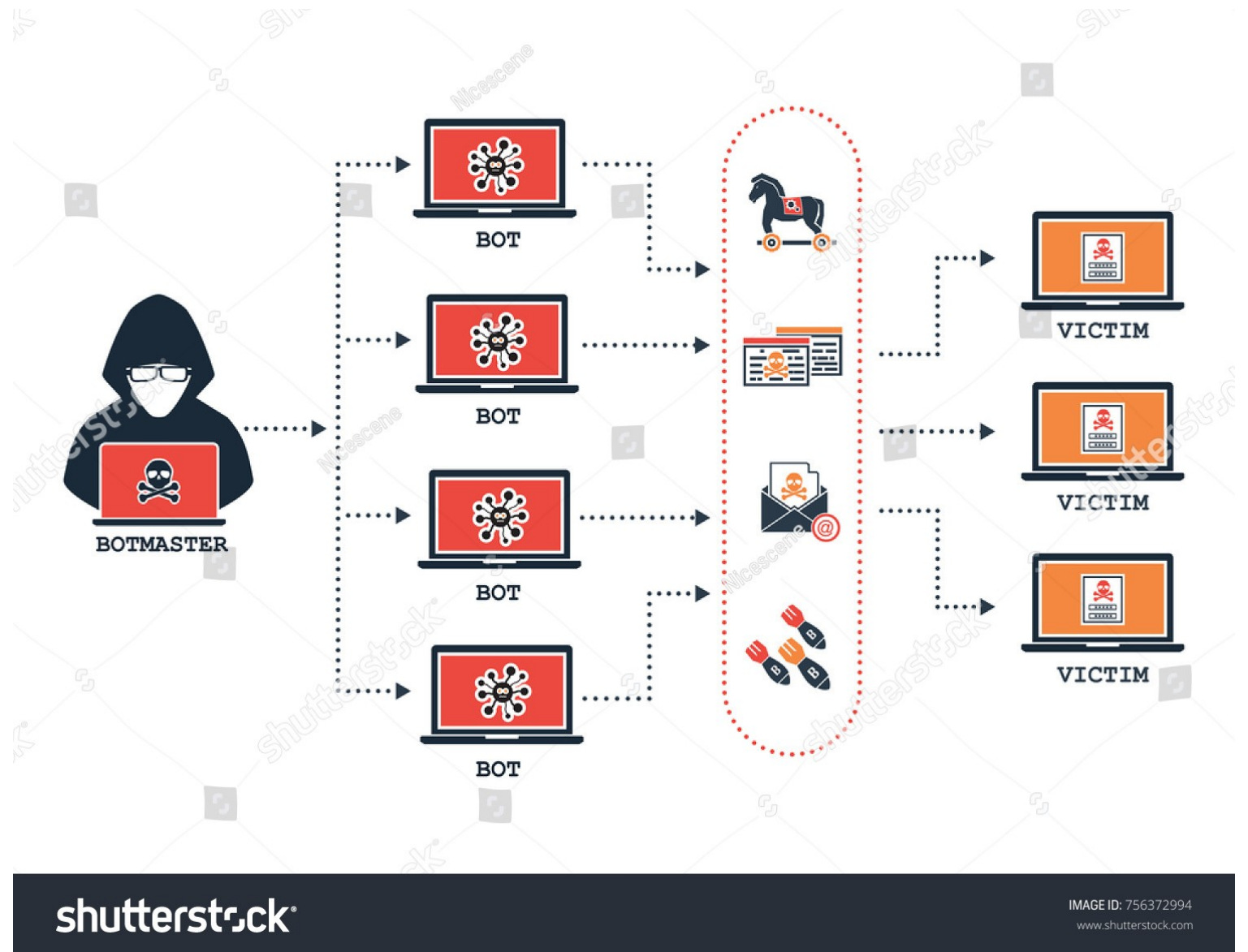
- Programmes conçus pour espionner les PC des victimes
- Apparaissent sous forme d'un jeu ou d'un utilitaire gratuit
- Surveillance de l'activité des utilisateurs via les cookies, les toolbars et autres techniques
- Certains spywares sont utilisés pour faire le *profiling* des clients pour des campagnes de marketing
- Souvent reconnus par le changement de la page d'accueil et l'installation de barres d'outils
- Peuvent rediriger l'internaute vers des pages non demandées



Botnets

- Une des menaces les plus dangereuses
- Programme qui se propage rapidement par divers moyens et reste caché
- Le maître du botnet contrôle à distance un grand nombre de Pc (100 000 et +)
- Difficulté de remonter au maître du bot car il est caché derrière plusieurs niveaux de contrôle du botnet
- Certains botnets appartiennent à des réseaux criminels (Mirai, Necurs)
- Les bots participent à des attaques diverses:
 - DDoS massif
 - opérations de piratage
 - Spam
 - Click-fraud ...

Botnets

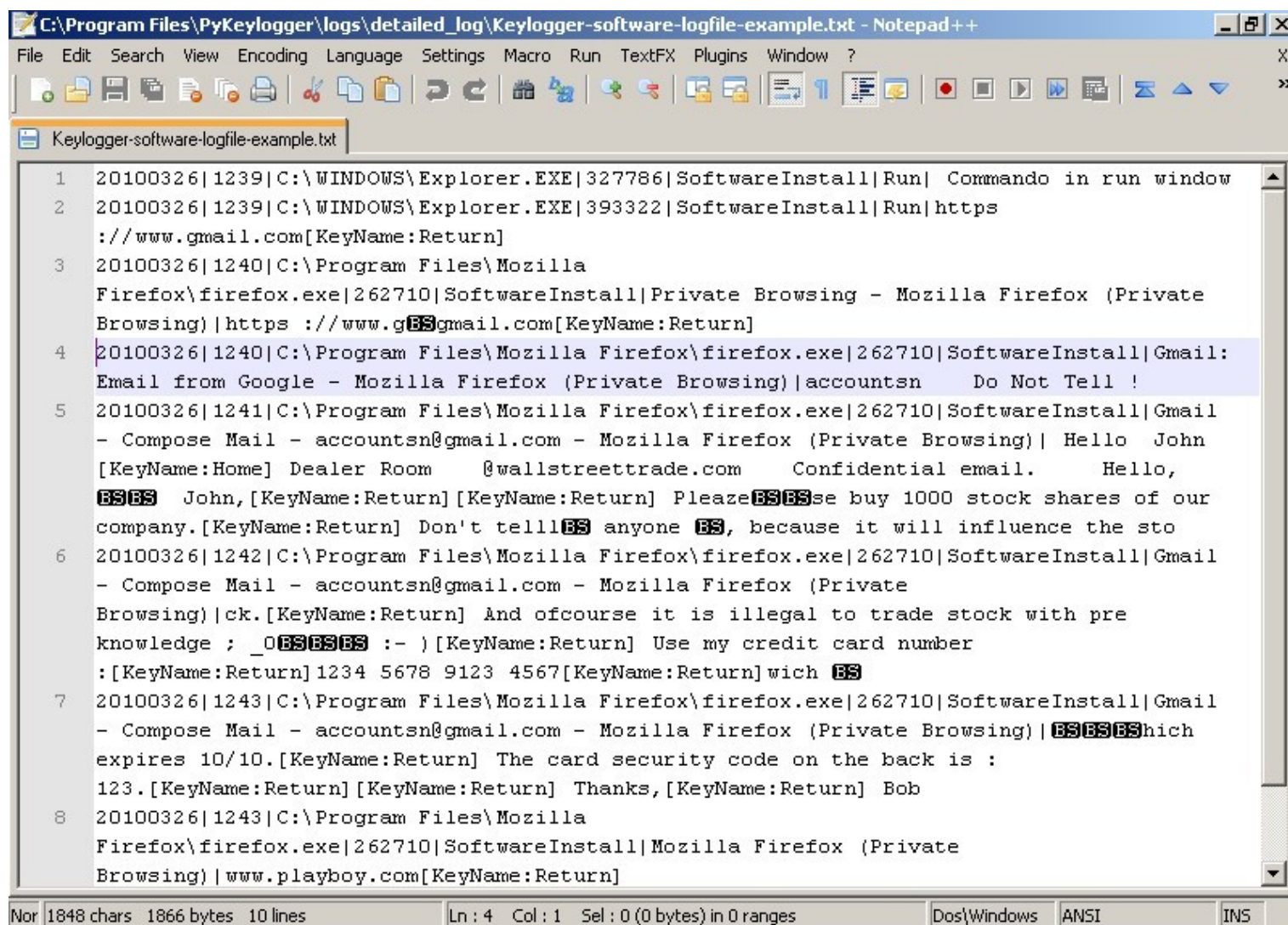


keylogger

- Programme ou dongle qui enregistre tout ce qui est tapé au clavier
- Enregistre les données et les envoie au pirate
- Permet de récupérer des mots de passe, des numéros de cartes de crédit
- Utilisé aussi dans l'espionnage industriel pour récupérer des rapports et des documents confidentiels
- Existe aussi sous forme d'un adaptateur USB
- Peut être utilisé pour de bonnes fins



Exemple de fichier log



```
C:\Program Files\PyKeylogger\logs\detailed_log\Keylogger-software-logfile-example.txt - Notepad++
File Edit Search View Encoding Language Settings Macro Run TextFX Plugins Window ?
Keylogger-software-logfile-example.txt
1 20100326|1239|C:\WINDOWS\Explorer.EXE|327786|SoftwareInstall|Run| Commando in run window
2 20100326|1239|C:\WINDOWS\Explorer.EXE|393322|SoftwareInstall|Run|https
  ://www.gmail.com[KeyName:Return]
3 20100326|1240|C:\Program Files\Mozilla
  Firefox\firefox.exe|262710|SoftwareInstall|Private Browsing - Mozilla Firefox (Private
  Browsing)|https ://www.gBSgmail.com[KeyName:Return]
4 20100326|1240|C:\Program Files\Mozilla Firefox\firefox.exe|262710|SoftwareInstall|Gmail:
  Email from Google - Mozilla Firefox (Private Browsing)|accounts Do Not Tell !
5 20100326|1241|C:\Program Files\Mozilla Firefox\firefox.exe|262710|SoftwareInstall|Gmail
  - Compose Mail - accounts@gmail.com - Mozilla Firefox (Private Browsing)| Hello John
  [KeyName:Home] Dealer Room @wallstreettrade.com Confidential email. Hello,
  BBS John,[KeyName:Return][KeyName:Return] PleaseBBSse buy 1000 stock shares of our
  company.[KeyName:Return] Don't tellB anyone BS, because it will influence the sto
6 20100326|1242|C:\Program Files\Mozilla Firefox\firefox.exe|262710|SoftwareInstall|Gmail
  - Compose Mail - accounts@gmail.com - Mozilla Firefox (Private
  Browsing)|ck.[KeyName:Return] And ofcourse it is illegal to trade stock with pre
  knowledge ; _OBBSBS :- )[KeyName:Return] Use my credit card number
  :[KeyName:Return]1234 5678 9123 4567[KeyName:Return]wich BS
7 20100326|1243|C:\Program Files\Mozilla Firefox\firefox.exe|262710|SoftwareInstall|Gmail
  - Compose Mail - accounts@gmail.com - Mozilla Firefox (Private Browsing)|BBSBSwhich
  expires 10/10.[KeyName:Return] The card security code on the back is :
  123.[KeyName:Return][KeyName:Return] Thanks,[KeyName:Return] Bob
8 20100326|1243|C:\Program Files\Mozilla
  Firefox\firefox.exe|262710|SoftwareInstall|Mozilla Firefox (Private
  Browsing)|www.playboy.com[KeyName:Return]
```

Nor 1848 chars 1866 bytes 10 lines Ln : 4 Col : 1 Sel : 0 (0 bytes) in 0 ranges Dos\Windows ANSI INS

Cheval de Troie

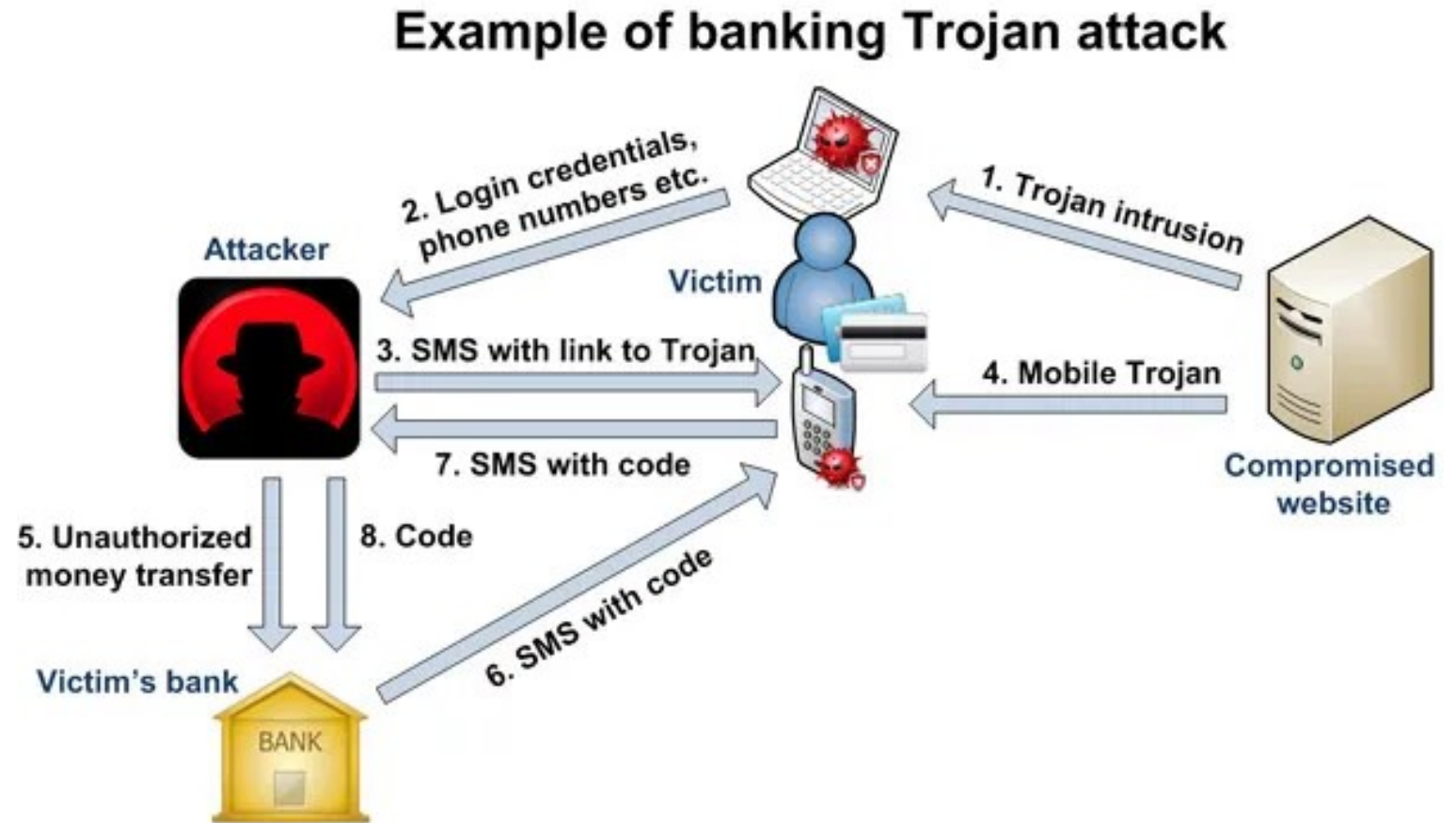


- Logiciel furtif qui vole des informations ou ouvre des comptes utilisateurs sur la machine victime
- Se cache dans un autre programme utile (jeu, crack, écran de veille, ...)
- Se lance automatiquement et n'apparaît pas lorsque le programme utile est lancé
- Ne se reproduit pas spontanément
- L'outil favori des hackers

Trojan: mode d'action

- Supprime ou remplace les fichiers système
- Génère un faux trafic pour provoquer des attaques DoS
- Enregistre le son, la vidéo et des screenshots sur le PC de la victime
- Télécharge d'autres malwares sur le PC
- Désactive les antivirus et pare-feux
- Utilise le PC de la victime comme proxy pour relayer des attaques
- Vole des informations confidentielles en activant un keylogger

Exemple de trojan bancaire



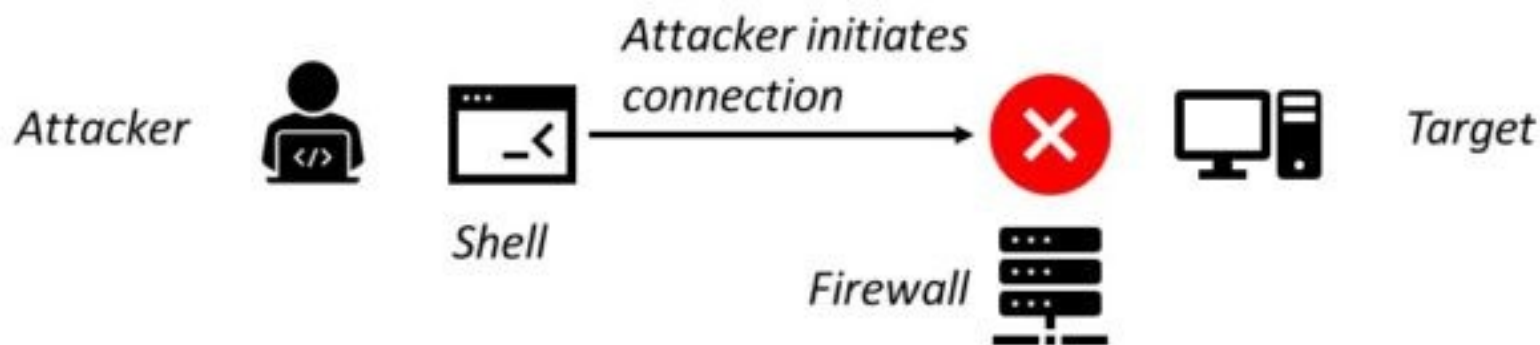
Porte dérobée (backdoor)

- ouvre un accès sur un ordinateur pour se connecter dessus à distance
- Profite d'une faille de sécurité critique
- Le hacker utilise cette faille par la suite pour contourner toutes les mesures de sécurité car il utilise une connexion sortante
- Le hacker n'a pas besoin d'authentification
- Le hacker a ensuite un accès total sur le PC et peut donc entrer sur le réseau local et les serveurs



Backdoor reverse shell

Without Reverse Shell



With Reverse Shell

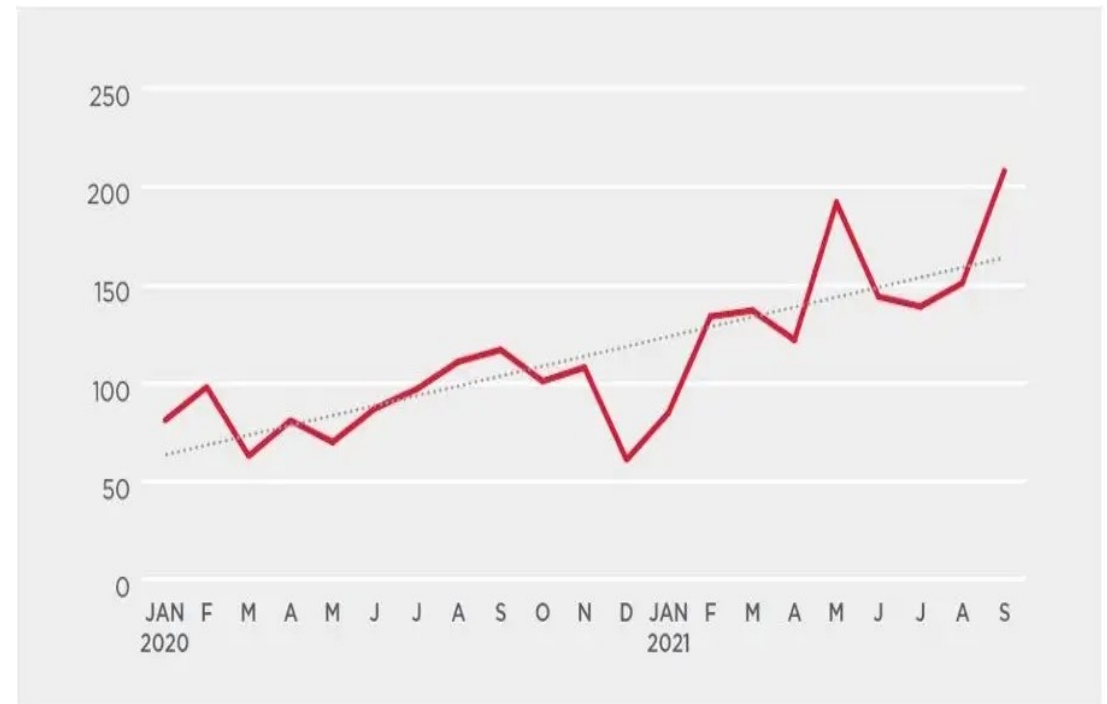


Bluesnarfing

- Attaque qui vise smartphones et équipements mobiles
- Utilise une faille dans le protocole bluetooth pour un accès non autorisé sur les équipements et accéder aux données
- Permet au hacker d'utiliser le téléphone pour dérober des informations, faire des appels ou se connecter au réseau de données

Ransomware

- Menace relativement nouvelle et à la mode
- Prend en otage un PC contre de l'argent
- Chiffre les données des utilisateurs et les efface après un timeout
- Bloque tous les accès à l'ordinateur
- Utilise le mail comme moyen principal de propagation



```
readme - Notepad
File Edit Format View Help
Greetings! Your files were stolen and encrypted.

You have two ways:

    -> Pay a ransom and save your reputation.
    -> Wait for a miracle and lose precious time.

We advise you not to wait.

After 2 days of your silence we will make a call your superiors and notificate them about what's happened.
After another 2 days all your competitors will be informed about your decision.
Finally, after 3 days we will post your critical data on our TOR-website.

If you are going to recover your files from backups and forget this like a nightmare, we are hurry to inform you - you can't prevent a leak.

Recommendations:

    -> Don't delete/rename encrypted files
    -> Don't use any public "decryptor", they contain viruses.

You have to download TOR browser.

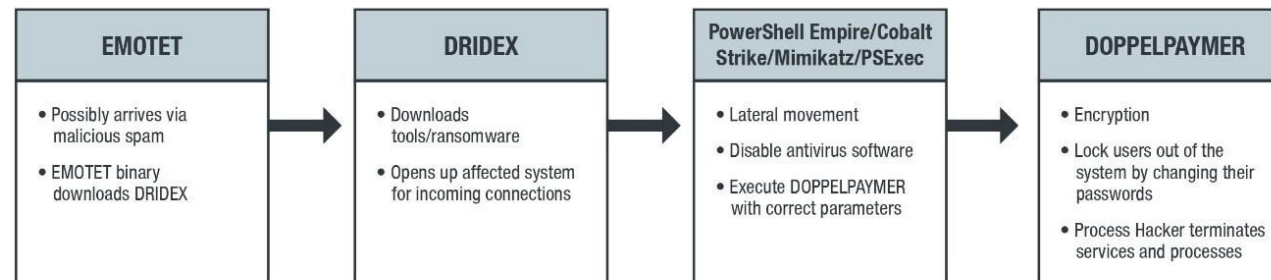
To contact with us your can use the following link:

    http://nevcorps5cvivjf6i2gm4uia7cxng5ploqny2ngrinctazjlnqr2yiyd.onion/63bb5b5ff541280c4bc116f2

The cat is out of the bag.
```

Exemples de ransomware

Nom	Apparition	caractéristiques
Maze	2019 -2020	Vol de données Rançon
Conti	2019	Vol et chiffrement de données Support technique
REvil	2019-2021	Code difficile à détecter Record de la plus grande rançon (50M\$)
Netwalker	2020-2021	Ransomware-as-a-service Publie le montant obtenu sur un site web
DoppelPaymer	2019	Version améliorée d'autres ransomwares



Classic vs. police-themed ransomware



Techniques de détection de malwares

- Exécuter le fichier suspect dans un environnement fermé et strictement contrôlé (sheep-dipping)
- Vérifier le fichier par un antivirus/antimalware mis à jour
- Voir les programmes de démarrage suspects
- Envoyer le fichier ou son hash à un site spécialisé:
 - www.virustotal.com
 - <https://www.hybrid-analysis.com>
 - www.sysinternals.com

Moniteur de
fichiers

Moniteur de
registre

Moniteur
des
permissions

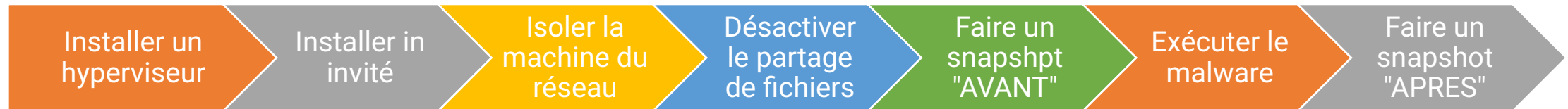
Moniteur
réseau

Moniteur
des ports

Moniteur de
processus

sheep-dip

Test de sheep-dipping



Méthodes de détection de malwares



- **Scan par un antivirus:** l'antivirus compare la signature du fichier avec sa base de signatures
- **Vérification de l'intégrité des fichiers:** contrôler les hashes et les dates de modification des fichiers importants pour détecter un changement non autorisé
- **Interception des écritures sur le disque:** faire le monitoring des écritures sur le disque pour détecter les opérations suspectes
- **Faire une analyse heuristique:** analyser les programmes pour chercher les comportements suspects
 - Forte utilisation CPU
 - Utilisation intensive/incorrecte de la mémoire
 - Création intensive de fichiers/processus
 - Utilisation de l'intelligence artificielle pour la classification

Mesures de protection

Ne pas ouvrir les
attachements de
mails suspects

Eviter de
télécharger des
applications de
sources
inconnues

Fermer les ports
non utilisés sur
les firewalls

Désactiver les
services inutiles

Contrôler le trafic
réseau

Installer les
mises à jour de
sécurité

Analyser les
supports avant
de les utiliser

Mettre des outils
de vérification de
l'intégrité des
fichiers

Exécuter un
antivirus ou un
EDR

Mettre à jour
l'antivirus

Faire des
sauvegardes
régulières des
données

Tests de pénétration pour les malwares

- 
- Scanner les ports ouverts, les processus, les entrées de registre, les lecteurs et les services
 - Pour chaque entrée suspecte vérifier le fichier exécutable associé
 - Obtenir des informations sur cet exécutable sur les sites spécialisés
 - Vérifier les programmes au démarrage
 - Vérifier les fichiers et les dossiers
 - Exécuter un anti-trojan
 - Isoler les fichiers suspects et nettoyer la machine